Report

HTMLi & XSS
(Hypertext markup language injection)

Suyash A Gunjal

Hypertext Markup Language Injection

What is Hypertext Markup Language Injection?

HTML injection is a type of attack where malicious HTML code is inserted into a website. This can lead to a variety of issues, from minor website defacement to serious data breaches. Unlike other web vulnerabilities, HTML injection targets the markup language that forms the backbone of most websites.

Types of HTML Injection:

1. Stored HTML Injection

Stored HTML injection, also known as persistent injection, is a type of attack where the malicious code is permanently stored on the target server. This code is then served to users every time they access a particular page. Once the malicious code is in place, it can affect many users without the attacker having to do anything further.

2. Reflected HTML Injection

Unlike stored injections, reflected attacks are not permanently housed on the server. Instead, they trick users into executing malicious code via a URL. This is often achieved through phishing emails or messages that lure users into clicking on a compromised link.

Mitigating HTML Injection Attacks:

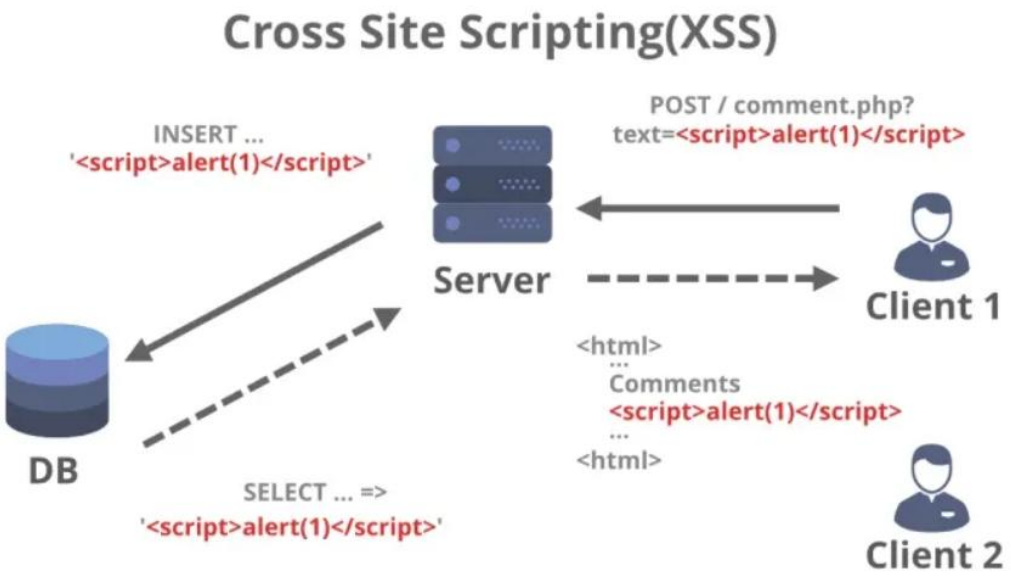
Detecting HTML injection starts by looking for HTML elements in the incoming HTTP stream that contains the user input. A naive validation of user input simply removes any HTML syntax substrings (like tags and links) from any user-supplied text.

There are many instances where the application expects HTML input from the user. For example, this happens when the user submits visually formatted text or text containing links to legitimate sites with related content. To avoid false positives, the security mechanism that detects possible injections and protects the application should learn in what application context user input is allowed to contain HTML. It should also be able to stop HTML input if it learns that such text is pasted as-is in a web page generated by vulnerable application components.

XSS (Cross Site Scripting)

What is Cross site scripting?

Cross-site scripting (also known as XSS) is a web security vulnerability that allows an attacker to compromise the interactions that users have with a vulnerable application. It allows an attacker to circumvent the same origin policy, which is designed to segregate different websites from each other.



(Working of Cross Site Scripting)

Types of XSS :

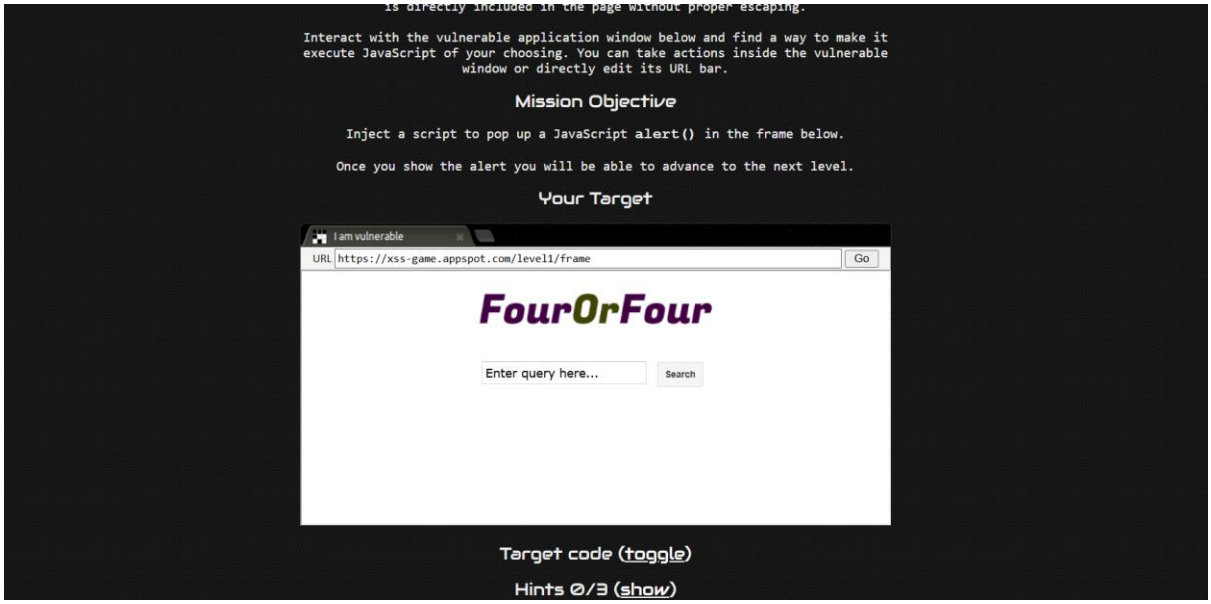
1. Reflected XSS

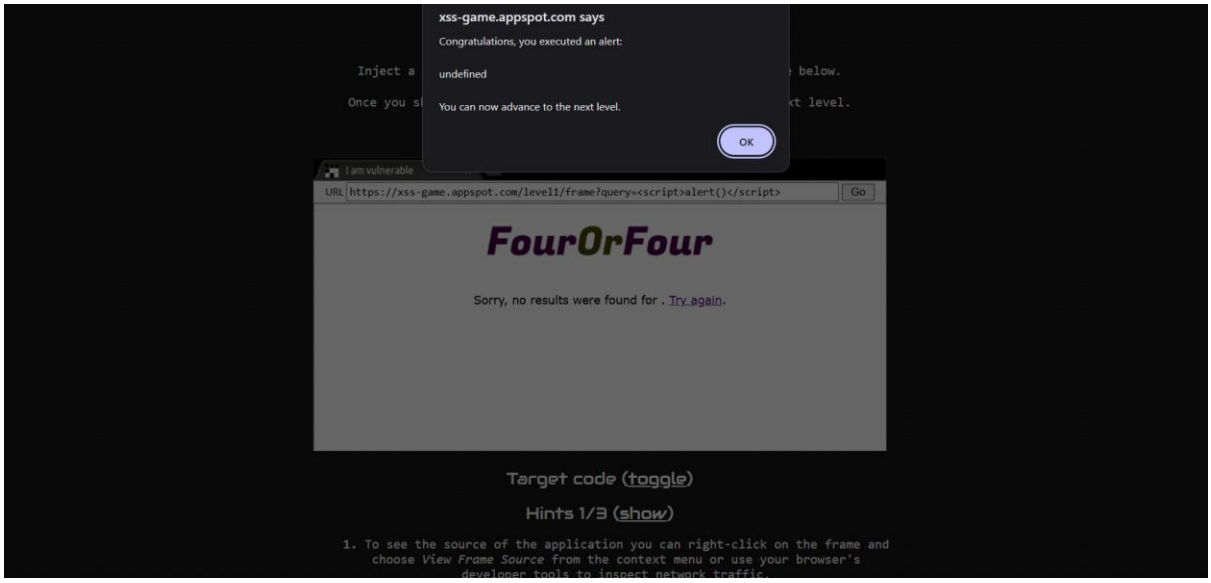
If the input has to be provided each time to execute, such XSS is called reflected. These attacks are mostly carried out by delivering a payload directly to the victim. Victim requests a page with a request containing the payload and the payload comes embedded in the response as a script.

2.Stored XSS

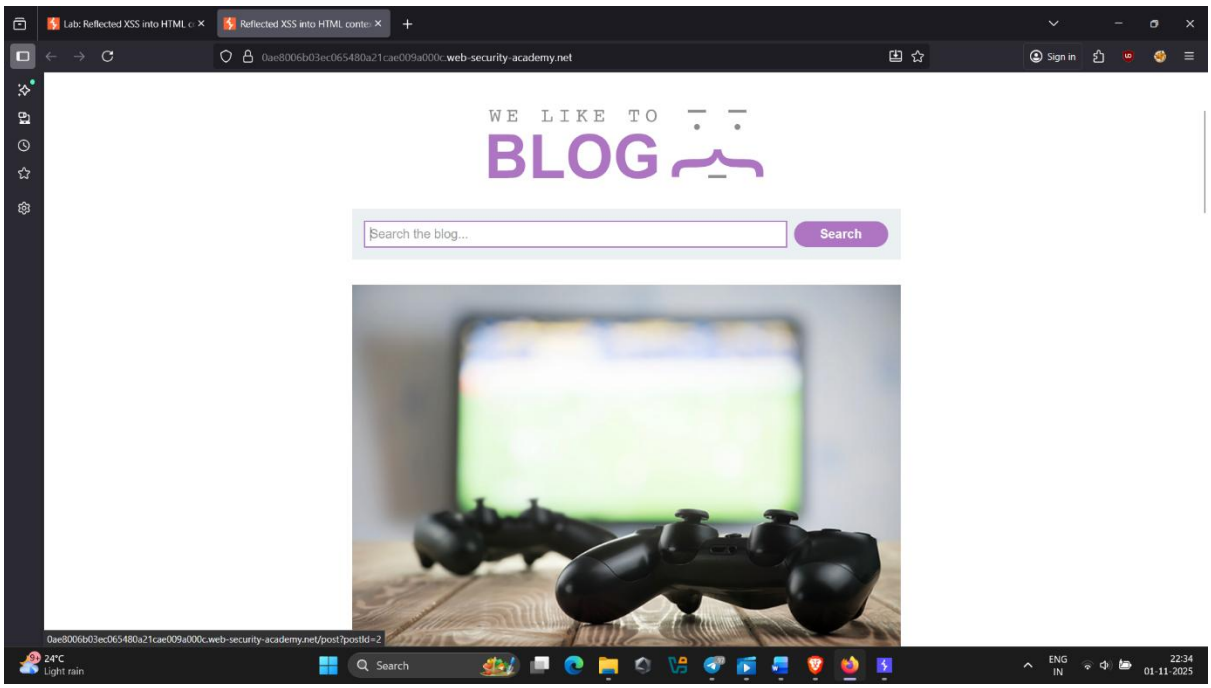
When the response containing the payload is stored on the server in such a way that the script gets executed on every visit without submission of payload, then it is identified as stored XSS.

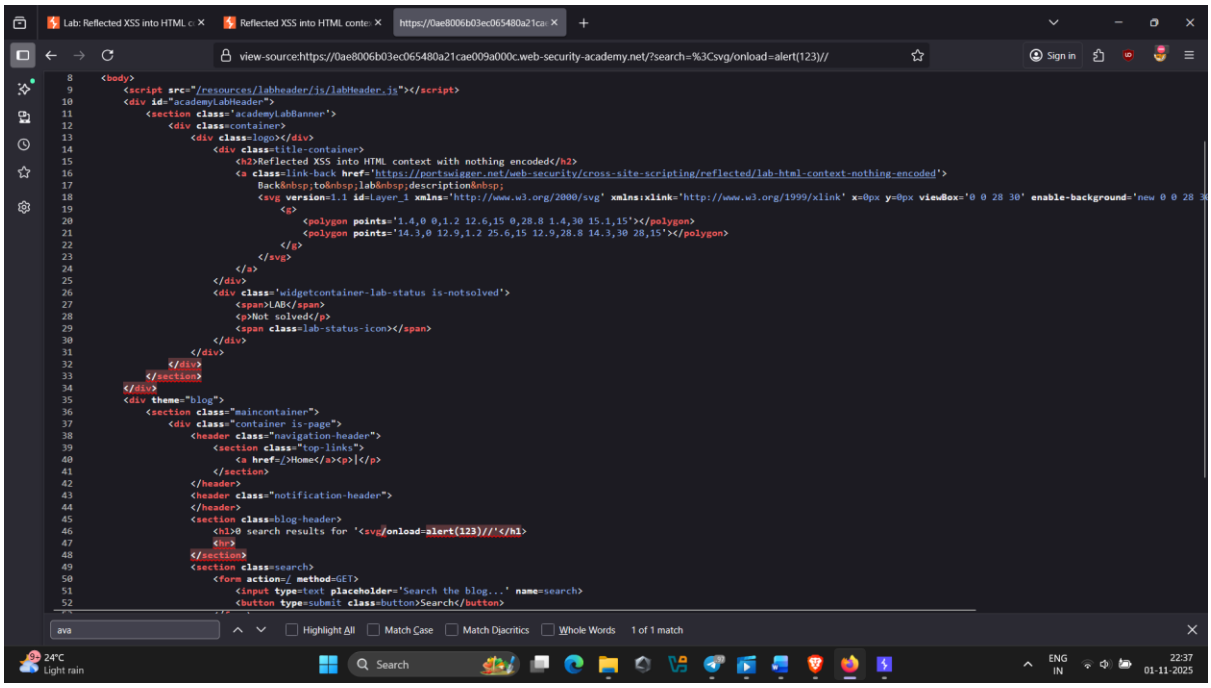
XSS GAME LEVEL 1 :

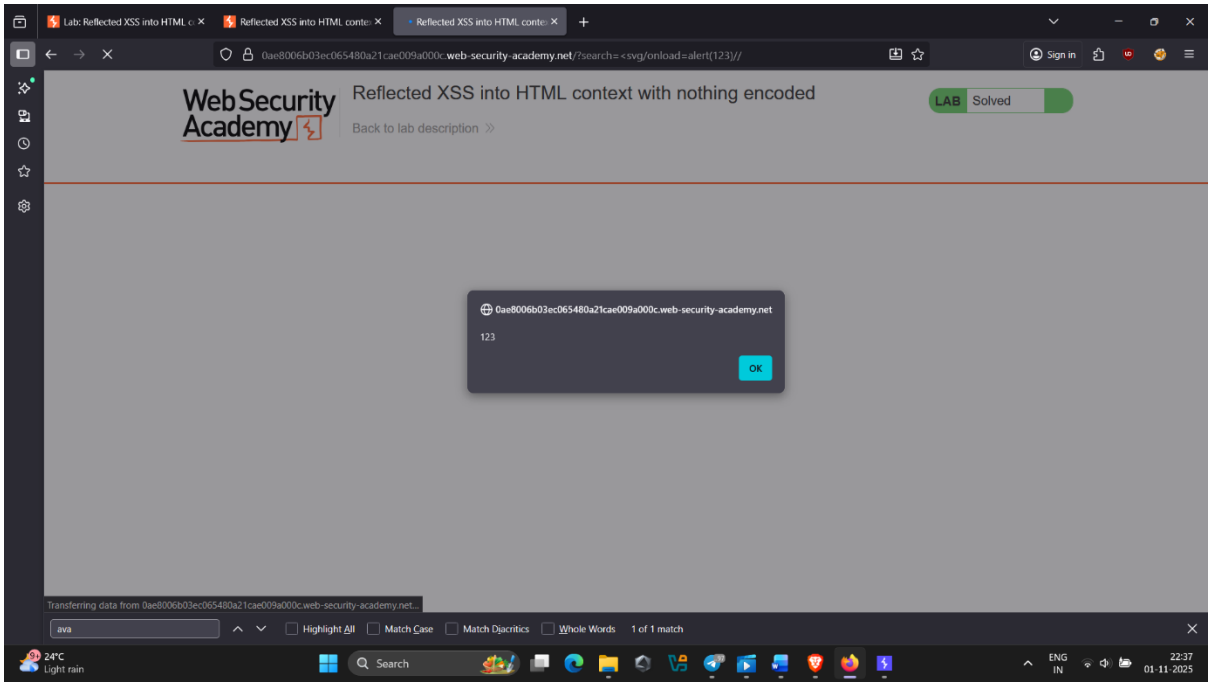


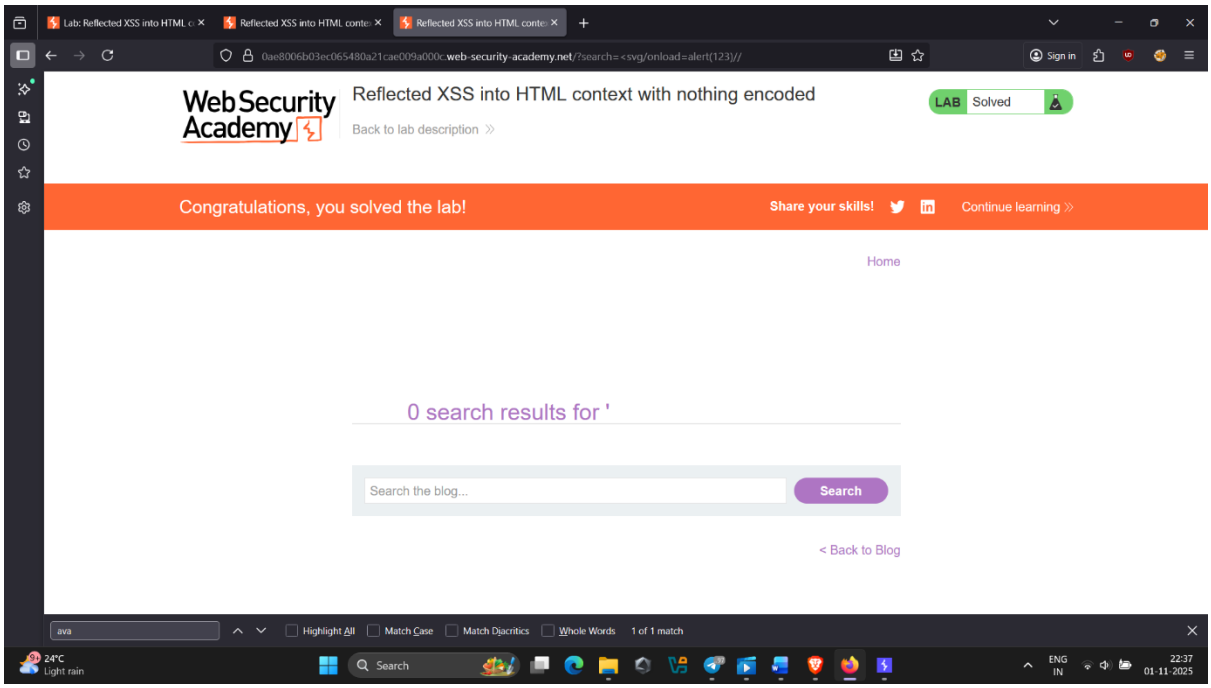


Portswigger Lab :









References:

https://www.imperva.com/learn/application-security/html-injection/

https://www.geeksforgeeks.org/ethical-hacking/what-is-cross-site-scripting-xss/